Experiment No. 3:Testing IoT Device Security (Default Passwords & Open Ports)

Aim

To analyze security weaknesses in a simulated IoT device by identifying:

- Open ports
- Running services
- Service version disclosure
- Default/weak authentication
- Unencrypted communication

Tools Used

- Windows 10 (Host System)
- Docker Desktop
- OWASP Juice Shop
- Kali Linux
- Nmap

Experimental Setup

- A vulnerable web application (Juice Shop) was deployed using Docker on Windows.
- Kali Linux was used as the attacker machine.
- The Windows system IP address was scanned from Kali Linux to simulate IoT network testing.

Attack Scenario Description

In this experiment:

- Kali Linux acted as the attacker machine.
- Windows system hosting the Docker container acted as the IoT device.
- The vulnerable web application (Juice Shop) simulated the IoT dashboard.
- Network scanning was performed from Kali to the Windows IP address over LAN.

This simulates a real-world scenario where an attacker scans an IoT device connected to the same network.

Procedure

Step 1: Deploy Vulnerable IoT Simulation

The following command was used to run Juice Shop in Docker:

docker run -d -p 8090:3000 --name juiceshop bkimminich/juice-shop

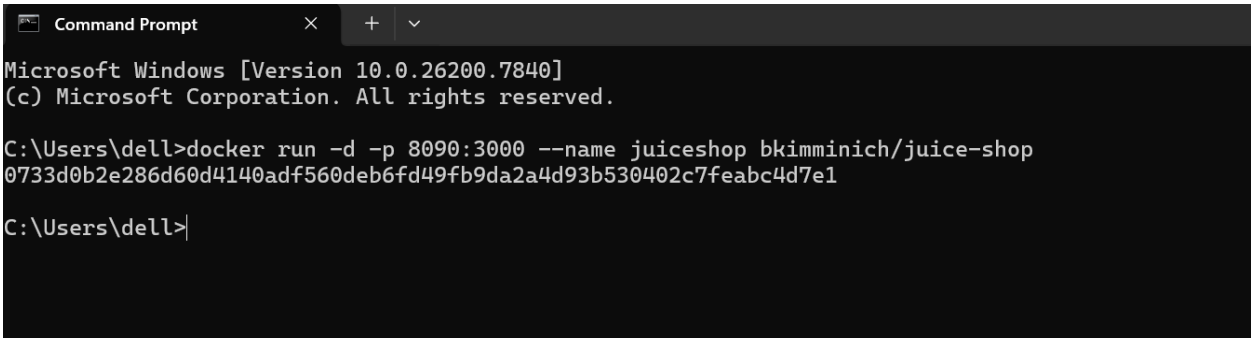


Figure 1: Deployment of simulated IoT device using Docker

The application was accessed at:

http://localhost:8090

Step 2: Identify Host IP Address

On Windows: ipconfig

```
C:\Users\dell>ipconfig

Windows IP Configuration


Unknown adapter Local Area Connection:

   Media State . . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :

Ethernet adapter Ethernet 3:

   Connection-specific DNS Suffix  . :
   Link-local IPv6 Address . . . . . : fe80::5cd0:b754:6025:656e%10
   Autoconfiguration IPv4 Address. . : 169.254.54.155
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . :

Wireless LAN adapter Local Area Connection* 1:

   Media State . . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :

Wireless LAN adapter Local Area Connection* 10:

   Media State . . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :

Wireless LAN adapter Wi-Fi:

   Connection-specific DNS Suffix  . : dlink
   Link-local IPv6 Address . . . . . : fe80::a080:af7:5ca0:94a7%17
   IPv4 Address. . . . . . . . . . . : 192.168.0.148
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 192.168.0.1
```

Figure 2: Host system IP address identification

Step 3: Perform Network Scan from Kali Linux

From Kali Linux terminal:

nmap -sV 192.168.0.148

This scan performed:

- Port scanning
- Service detection
- Version detection
- Banner grabbing

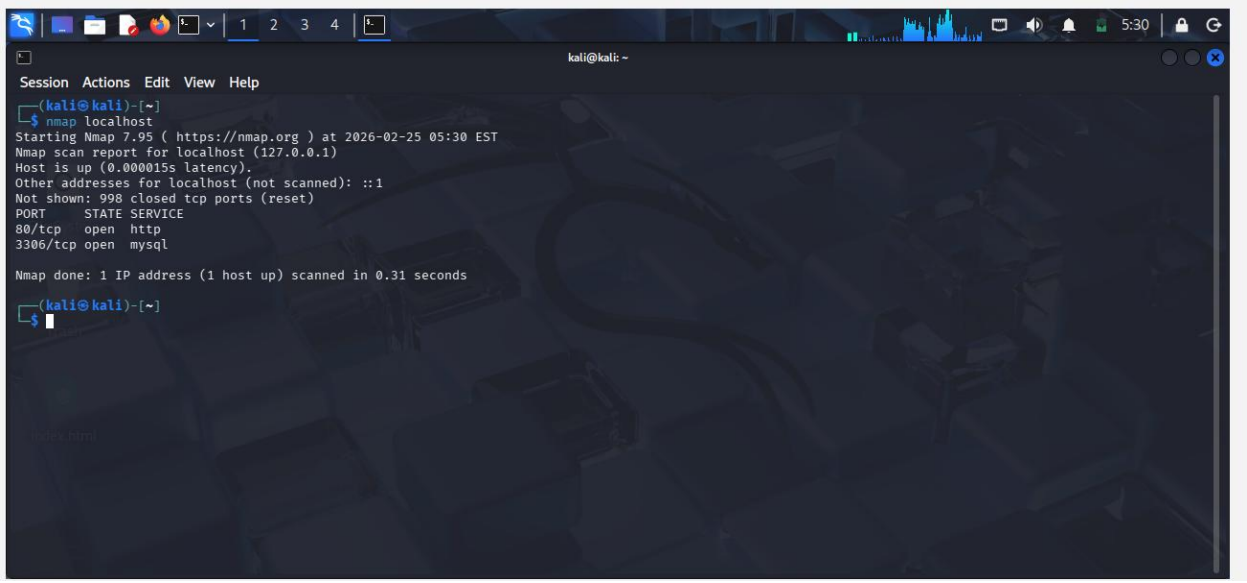
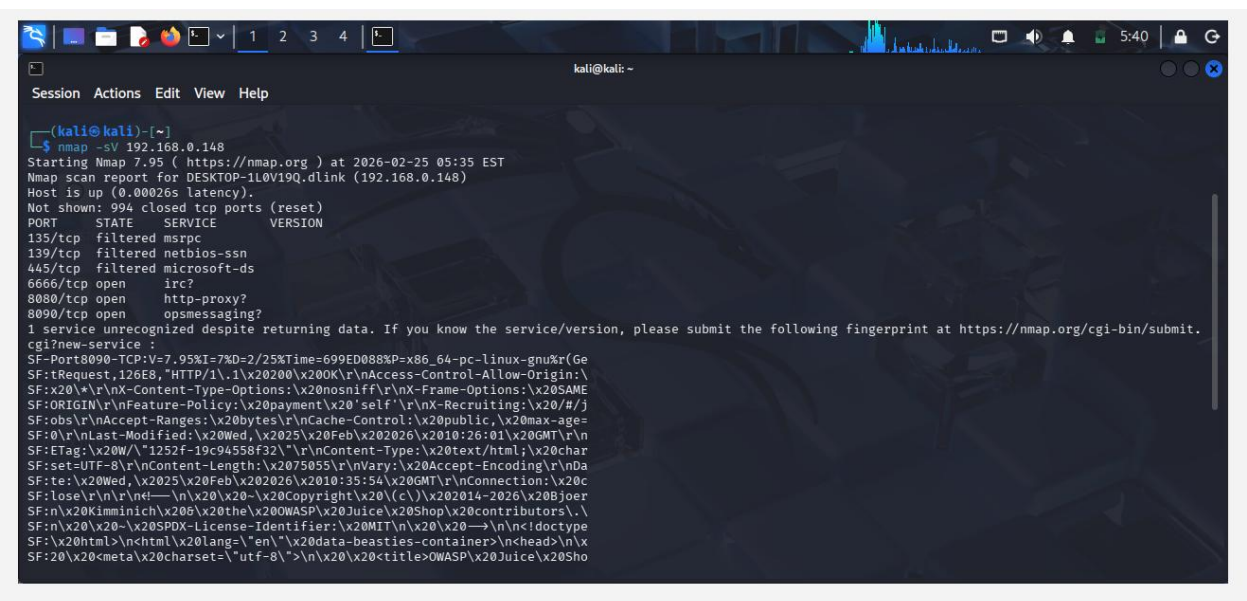


Figure 3: Open ports and service enumeration using Nmap

Step 4: Nmap Version Scan (-sV)

- nmap -sV 192.168.x.x output
- Showing service fingerprint / version detection



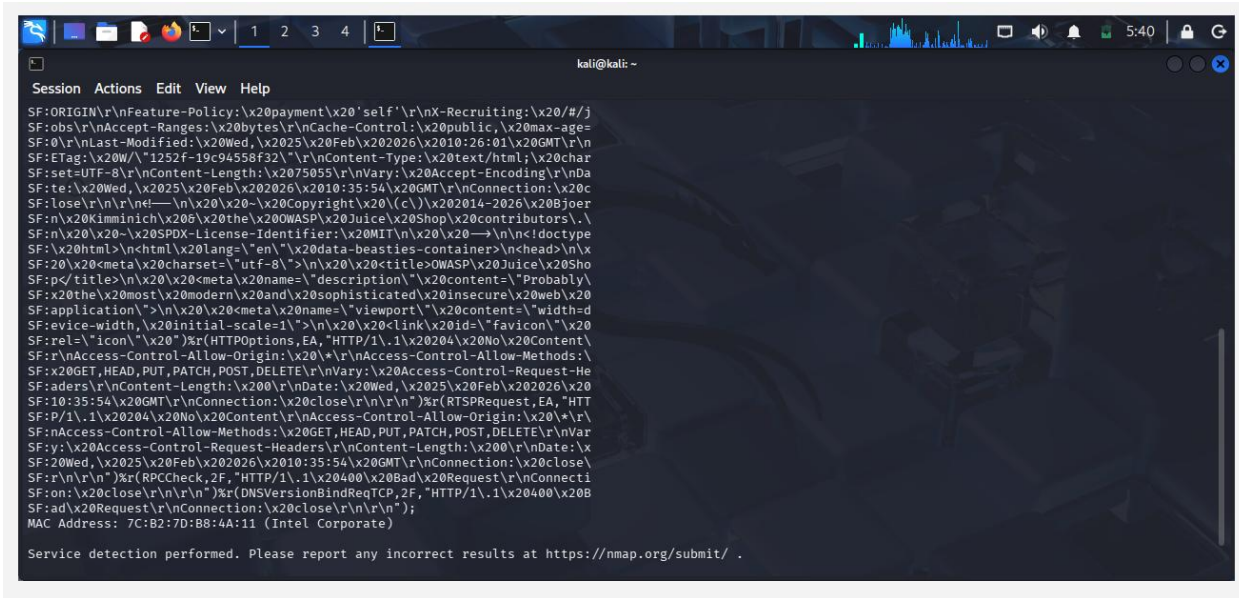


Figure 4: Service enumeration and version detection

Step 5: Accessing the IoT Device Web Dashboard

The simulated IoT device dashboard was accessed through the browser using: http://localhost:8090

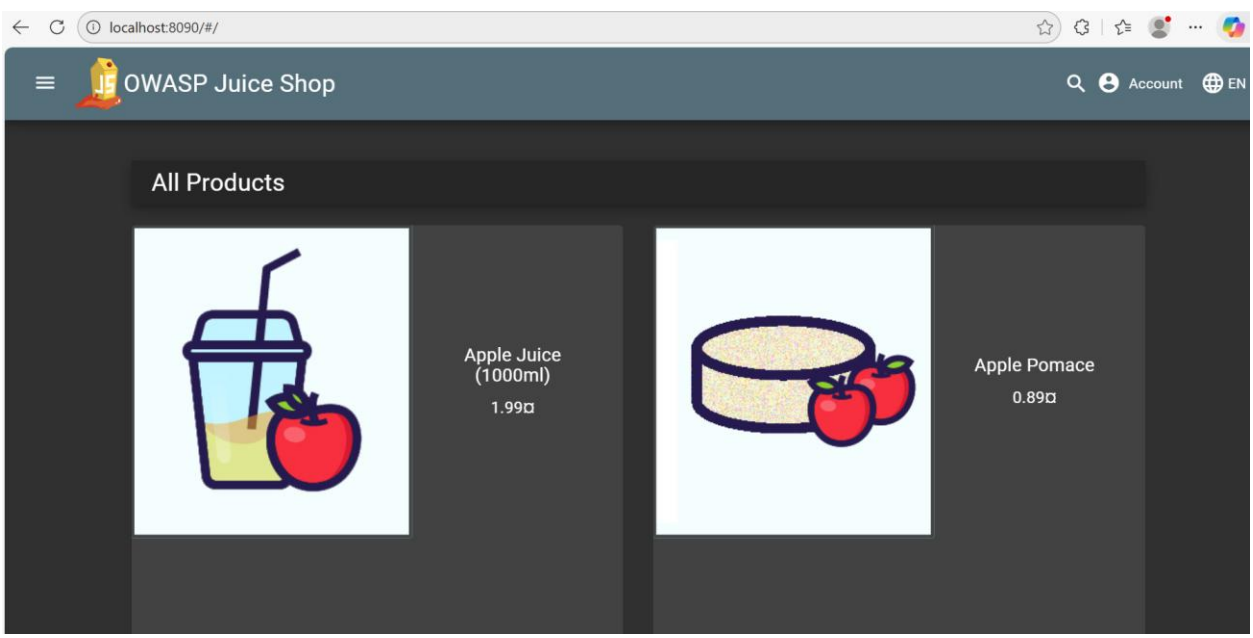


Figure 5: Simulated IoT device web dashboard running on port 8090

Step 6: Testing Default/Weak Credentials

The login functionality was tested using administrator credentials to check for default password vulnerability

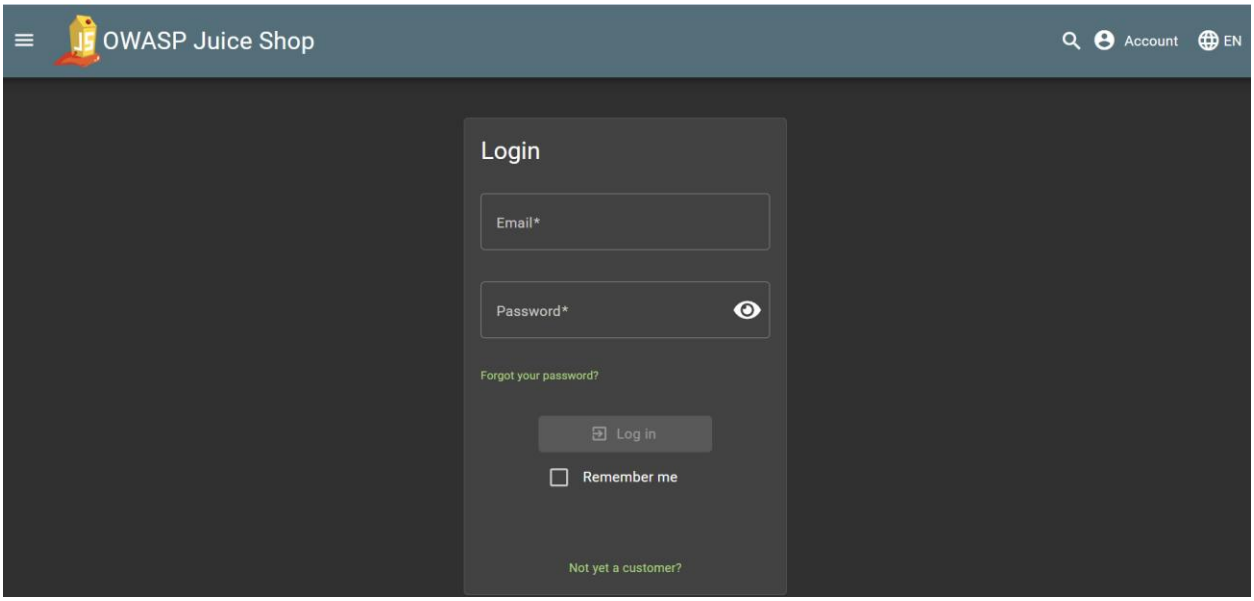


Figure 6: IoT device login interface

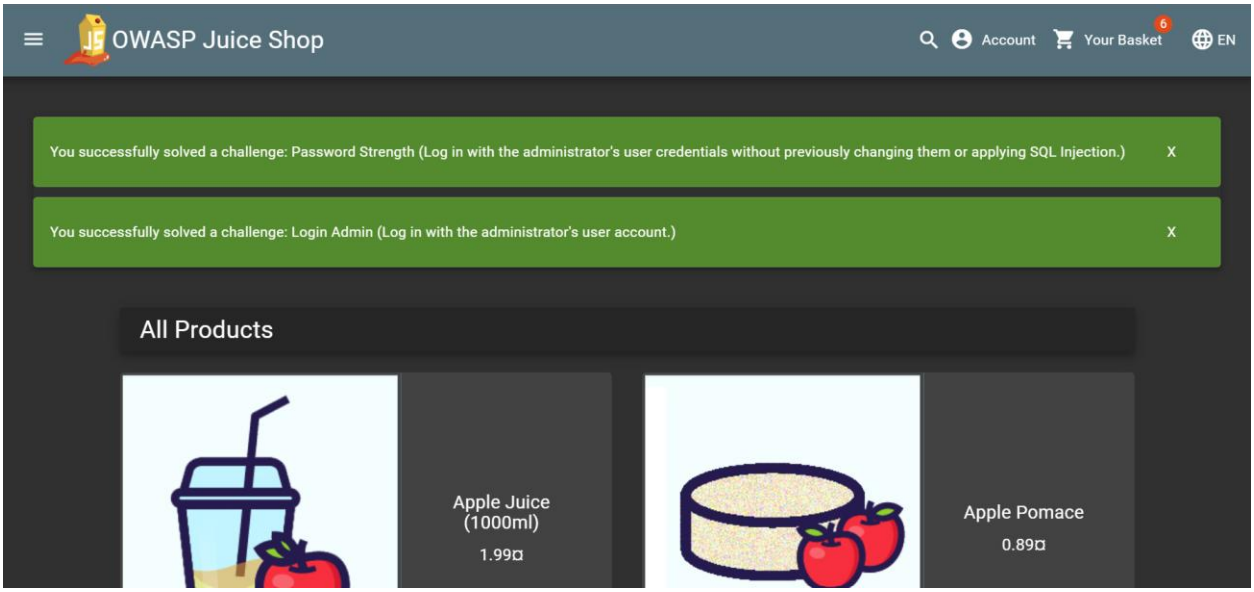


Figure 7: Successful login using default/weak credentials

Successful login using administrator credentials demonstrates the risk of default or weak passwords in IoT devices. If default credentials are not changed after deployment, attackers can gain unauthorized administrative access.

Step 7: Developer Tools → Network Tab

- Network tab showing HTTP requests
- Plain text traffic visible

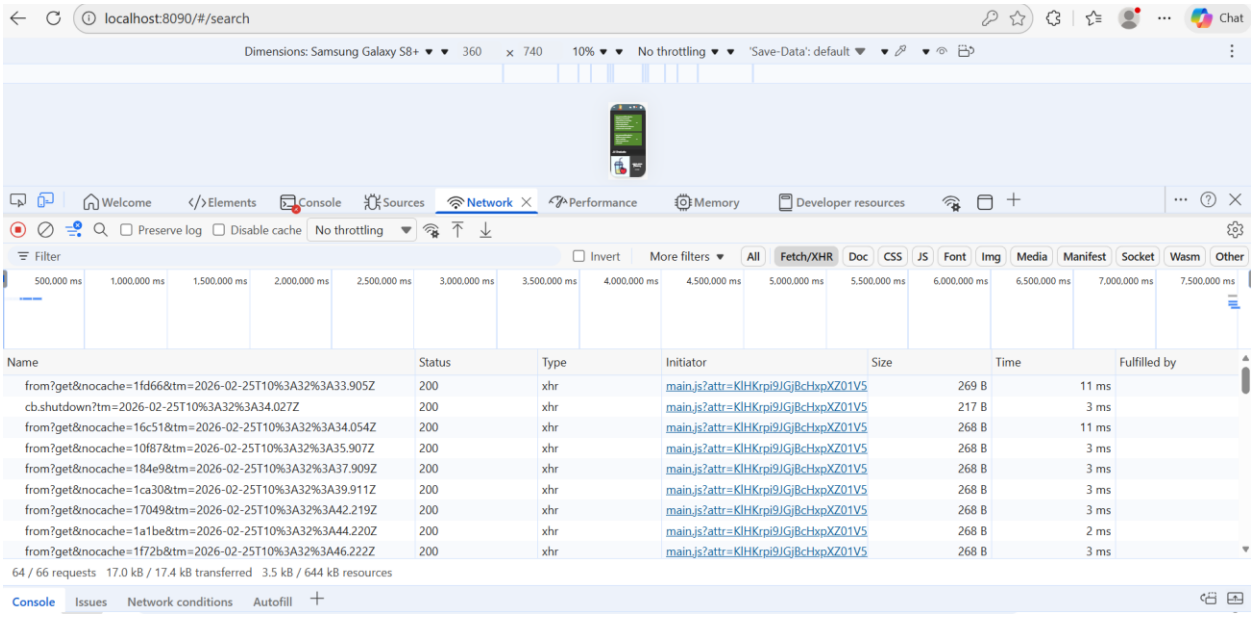


Figure 8: Unencrypted HTTP communication analysis

Observations

The scan revealed:

- Port 8090 open (HTTP service running).
- Service fingerprint identified as Juice Shop.
- Windows system ports (135, 139, 445) visible.
- Service version information exposed.
- MAC address detected.
- Web communication running over HTTP (not HTTPS).

Using Browser Developer Tools:

- Network requests visible in plain text.
- No SSL/TLS encryption detected.

Vulnerabilities Identified

1. **Open Port Exposure**
    - Port 8090 accessible over network.
    - Increases attack surface.
2. **Service Enumeration**
    - Service version and fingerprint visible.
    - Enables targeted exploit attempts.
3. **Unencrypted Communication**
    - Application runs over HTTP.
    - Data transmitted in plain text.
4. **Weak Authentication Risk**
    - Login interface exposed.
    - No strict account lockout mechanism.
5. **Information Disclosure**
    - Banner reveals application identity.
    - Server headers visible.

Conclusion

The experiment demonstrated how an attacker on the same network can identify open ports, detect running services, and test default credentials on an IoT device. The presence of exposed services and unencrypted communication highlights common IoT security risks. Proper configuration, strong authentication, and secure communication protocols are essential to protect IoT devices from exploitation.